

Grundlagen der IT-Sicherheit Praktikum

WS 22 / 23

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 4

Lernziele: Verschlüsseln und signieren mit GPG.

Abgabetermin wird in FELIX bekannt gegeben

In der Vorlesung haben Sie die asymmetrische Verschlüsselung kennengelernt. Hiermit ist es möglich, Nachrichten und Dateien mit dem öffentlichen Schlüssel zu verschlüsseln, sodass nur der Inhaber des privaten Schlüssels die Nachricht wieder lesen kann. Zusätzlich ist es möglich Nachrichten zu signieren, womit die Quelle einer Nachricht nachgewiesen werden kann.

In den folgenden Aufgaben wenden Sie beide Verfahren auf Dateien und E-Mails an. Hierfür nutzen Sie GPG (Gnu Privacy Guard). Wir werden E-Mails signieren und verschlüsseln.

Aufgabe 1: Signieren, verschlüsseln und entschlüsseln

Installieren Sie GPG von <https://gnupg.org/download/index.html> oder nutzen Sie ihren Paketmanager. Scrollen Sie auf der Webseite nach unten, bis Sie eine Version für Ihr Betriebssystem und Rechner finden.

Nach der Installation können Sie das Tool `gpg` in der Konsole (Eingabeaufforderung) nutzen. Machen Sie sich mit den einzelnen Optionen und den Schaltern vertraut: Rufen Sie `gpg --help` auf.

- a) Erstellen Sie ein Schlüsselpaar mit dem Befehl `gpg --gen-key`. Geben Sie Ihre `hs-furtwangen.de` E-Mail-Adresse und Ihren korrekten Namen an, damit der spätere E-Mail-Versand mit diesem Schlüsselpaar korrekt funktioniert. Wählen Sie ein sicheres Passwort, um den privaten Schlüssel zu sichern. Fügen Sie der Abgabe einen Screenshot der Ausgabe von `gpg -k` an. Dieser sollte ungefähr so aussehen:

```
C:\Users\Richard Zahoransky>gpg -k
C:/Users/Richard Zahoransky/AppData/Roaming/gnupg/pubring.kbx
-----
pub   rsa3072 2021-11-13 [SC] [verfällt: 2023-11-13]
      93AD24D864861262B705E55EF77DB9A857755314
uid   [ ultimativ ] Richard Zahoransky <richard.zahoransky@hs-furtwangen.de>
sub   rsa3072 2021-11-13 [E] [verfällt: 2023-11-13]
```

Sie haben hiermit öffentliche und private Schlüssel erzeugt. Dieser Schlüssel ist identifizierbar über seinen Fingerprint (hier: 93AD24...314). Sie können sich Details zum zugehörigen privaten Schlüssel mit `gpg -K` ansehen.

- b) Damit Sie später Nachrichten untereinander verschlüsselt austauschen können, müssen Sie Ihre öffentlichen Schlüssel exportieren. Der Export von Schlüsseln kann in binärer Form erfolgen. Bei der Übertragung eines Schlüssels per E-Mail oder anderen Medien kann dies jedoch zu Problemen führen, wenn nur druckbare Zeichen möglich sind. Daher ermöglicht `gpg` die Erzeugung der Schlüssel im ASCII-Format. Hierfür wird der Schalter `--armor` benutzt. Ein öffentlicher Schlüssel lässt sich mit der Option `--export` exportieren. Exportieren Sie Ihren öffentlichen Schlüssel mit

`gpg --output <Vor.Nachname>.gpg --armor --export`. Laden Sie die Datei im Felixkurs hoch, damit jeder Zugriff auf Ihren öffentlichen Schlüssel hat.

- c) Sie können nun das Tool nutzen, um einzelne Dateien zu signieren und zu verschlüsseln. Erstellen Sie eine Datei mit Ihrem Namen und beliebigem Inhalt, z.B.: „Ich überweise 50 Euro“. Diese Datei werden Sie signieren, damit ein Empfänger prüfen kann, dass diese Datei tatsächlich von Ihnen erstellt und bei der Übertragung nicht verändert wurde. Nutzen Sie den Befehl `gpg --detach-sign <Datei>`. GPG nutzt hierfür automatisch den zuvor erstellten Schlüssel. Es wird eine neue Datei mit der Endung `.sig` erstellt. Dies stellt die Digitale Signatur dar. Laden Sie sowohl die Datei, als auch die Signatur in Felix hoch.
- d) Prüfen Sie die Korrektheit einer anderen Textdatei aus einem anderen Ordner in Felix, indem Sie die zugehörigen Signaturen prüfen. Lesen Sie die Ausgabe von `gpg --help` oder informieren Sie sich im Internet, wie sich eine Signatur prüfen lässt. Nutzen Sie bitte (noch) nicht die Datei von richard.zahoransky@hfu.eu. Wieso hat die Prüfung der Signatur zu diesem Zeitpunkt noch keine Bedeutung? Geben Sie einen Screenshot der Ausgabe einer Prüfung an.
- e) Laden Sie nun zusätzlich den öffentlichen Schlüssel, der anderen Teilnehmer von Felix herunter. Importieren Sie die öffentlichen Schlüssel. Lesen Sie hierfür die Ausgabe von `gpg --help`. Unter Linux können Sie mit der Eingabe `man gpg` die „manpages“ von gpg lesen. Dies ist eine Erläuterung zu den einzelnen Befehlen von gpg. Alternativ können Sie das Internet durchsuchen. Welchen Befehl zum Importieren benutzen Sie? Funktioniert die Prüfung der Signatur nun? Können Sie sich sicher sein, dass die importierten Schlüssel wirklich zu den Personen gehören, die Sie vermuten?
- f) Signieren Sie die erhaltenen Schlüssel. Dieser Vorgang bedeutet, dass Sie geprüft haben, dass der gegebene öffentliche Schlüssel wirklich zu der korrekten Person gehört. Sprechen Sie hierfür mit Ihren Mitstudierenden und prüfen Sie die Fingerprints der erhaltenen Schlüssel. Signieren Sie den öffentlichen Schlüssel, indem Sie die Option `--edit-key` nutzen:
`gpg --edit-key <Name/E-Mail-Adresse des Schlüssels>`
Daraufhin können Sie Ihr Vertrauen in den Schlüssel setzen. Nutzen Sie den Befehl `trust` und `tsign`. Folgen Sie daraufhin den Anweisungen. Wählen Sie die „Trust-Tiefe“ 2. Bei der Frage nach der Einschränkung einer Domäne, geben Sie bitte nichts ein. Können Sie jetzt die Signatur der Dateien aus Felix prüfen? Was sagt dies aus? Erklären Sie, wie das Konzept von Vertrauen mit dem Signieren eines Schlüssels gemein hat. Geben Sie am Ende die Ausgabe von `gpg --k` an. Interpretieren Sie die Ausgabe.
- g) Ändern Sie die erhaltene vom Felix-Kurs Datei ab. Prüfen Sie erneut die Signatur. Geben Sie einen Screenshot der Ausgabe an. Was bedeutet die Ausgabe?
- h) Wiederholen Sie den Austausch von Dateien. Zusätzlich signieren **und verschlüsseln** Sie die Datei jedoch. Sprechen Sie in der Gruppe ab, für wen die Datei bestimmt ist. Der Aufruf, um eine Datei zu verschlüsseln und für einen Empfänger zu verschlüsseln lautet:
`gpg --encrypt --sign --armor -r Empfänger Dateiname`.
Dabei lässt sich der Empfänger über seine E-Mailadresse oder über den Fingerprint des Schlüssels auswählen. Die Ausgabe des Befehls ist eine neue Datei mit der Endung `.asc`

- i) Prüfen Sie die Signatur und entschlüsseln Sie die erhaltene Datei mit `gpg <Datei.asc>`. Geben Sie einen Screenshot der Ausgabe an.

Aufgabe 2: Aufbau einer „Chain of Trust“

In der vorherigen Aufgabe haben Sie öffentlichen Schlüssel explizit vertraut. Dies bedeutet, dass Schlüssel stets ausgetauscht und geprüft werden müssen. Stattdessen ist es möglich, das Vertrauen (abgebildet durch die Signatur eines öffentlichen Schlüssels durch einen anderen Schlüssel) weiterzureichen. Stellen Sie sich vor, dass Sie allen Schlüssel Ihres Kurses vertrauen. Einer Ihrer Mitstudierenden vertraut nun einem weiteren Schlüssel, den Sie noch nicht kennen. Sie könnten also auch dem unbekannten Schlüssel vertrauen.

- a) Sie haben alle Ihre Schlüssel gegenseitig signiert. Das heißt, Sie haben Ihr Vertrauen in die Korrektheit und die Identität der Schlüssel mit Ihrer Signatur bestätigt. Zusätzlich haben Sie mit `tsign` Ihrer lokalen GPG-Instanz mitgeteilt, dass Sie auch Schlüsseln vertrauen, die durch Ihre Mitstudierenden signiert werden. Dieses „verkettete Vertrauen“ können Sie nutzen. Exportieren Sie zunächst die erhaltenen, öffentlichen Schlüssel Ihrer Mitstudierenden mitsamt Ihrer eigenen Signatur. Dies geschieht mit dem Befehl `gpg --output <Ausgabedatei> --armor --export <Schlüssel-ID oder E-Mail des signierten Schlüssels>`.
Führen Sie diesen Befehl für einen der erhaltenen, öffentlichen Schlüssel aus. Vergleichen Sie die Ausgabe mit dem ursprünglich erhaltenen Schlüssel. Worin besteht der Unterschied? Was sagt Ihre Signatur für andere aus?
- b) Bitte melden Sie sich bei mir, falls Sie bereits bis zu dieser Aufgabe gekommen sind. Sie erhalten den öffentlichen Schlüssel von richard.zahoransky@hfu.eu. Unsere Schlüssel werden wir dann gegenseitig mit `tsign > 1` signieren. Auf diese Weise kann das Vertrauen, welches Sie dem Schlüssel von richard.zahoransky@hfu.eu geben an Ihre Kommilitonen weitergegeben werden.
- c) Mindestens eine Person, dessen Schlüssel Sie vertrauen hat den Schlüssel für richard.zahoransky@hfu.eu signiert und diese Signatur mit dem Befehl aus Aufgabe a) exportiert. Sie finden im Felix-Kurs diesen signierten Schlüssel (für [richard.zahoransky](mailto:richard.zahoransky@hfu.eu)). Importieren Sie diesen Schlüssel.
- d) Prüfen Sie die Signatur der Datei `ChainOfTrust.txt`. Von wem stammt die Datei. Wieso vertraut `gpg` dieser Signatur, obwohl Sie die Identität von richard.zahoransky@hfu.eu nicht selbst geprüft haben?

Aufgabe 3: Nutzen von GPG für den E-Mail-Versand

Die gängigen E-Mailprogramme haben Plugins, um mit Schlüsseln von GPG zu arbeiten. Somit müssen Sie die oben gelernten Befehle nicht von Hand nutzen.

- a) Installieren Sie Thunderbird. Richten Sie Ihre @hs-furtwangen.de Adresse hiermit ein.
- b) Exportieren Sie Ihren privaten Schlüssel in die Datei `secret-key.gpg` mit `gpg -o secret-key.gpg --export-secret-key`.
- c) Exportieren Sie die von Ihnen signierten, öffentlichen Schlüssel (inklusive des Schlüssels Ihres Tutors) mit `gpg -o pub-keys.gpg --export`.

- d) Klicken Sie rechts auf Ihr E-Mail-Konto und wählen Sie Einstellungen -> Ende-zu-Ende-Verschlüsselung. Importieren Sie Ihren privaten Schlüssel, indem Sie auf „Schlüssel hinzufügen“ klicken.
- e) Importieren Sie Ihre privaten Schlüssel, indem Sie die OpenPGP Schlüsselverwaltung öffnen und darin unter dem Menüpunkt Datei „öffentliche Schlüssel importieren“ wählen.
- f) Sie können nun E-Mails signiert und verschlüsselt senden. Nicht einmal der Betreiber des E-Mailservers könnte die von Ihnen verschlüsselten E-Mails lesen. Teilen Sie untereinander E-Mails aus und legen einen Screenshot der Signatur- und Schlüsselprüfung ab.

Hinweis für die Benutzung „in real life“.

GPG kann auch sogenannte Key-Server nutzen, die weltweit bekannt und zugänglich sind. Zum Beispiel können Sie mit dem Befehl

```
gpg --keyserver search.keyserver.net --send-key you@example.com
```

Ihren öffentlichen Schlüssel (mitsamt den Signaturen) für Ihre E-Mailadresse auf dem Server search.keyserver.net hochladen.

Dies vereinfacht den Umgang mit E-Mails. Sie können Signaturen für erhaltene Schlüssel herunterladen und dies ermöglicht Ihnen auch den Versand von verschlüsselten E-Mails an Empfänger, dessen öffentlichen Schlüssel Sie noch nicht kennen.

Mit

```
gpg --keyserver keyserver --search-keys <E-Mailadresse / Name>
```

können Sie nach Schlüsseln für eine bestimmte E-Mailadresse oder einem Namen suchen.

Mit

```
gpg --keyserver keyserver --recv-keys FBF1FC87DAD95197
```

können Sie dann die Schlüssel mit den gefundenen IDs herunterladen und bei Ihnen importieren.

Grafische Oberflächen können den Import und Export automatisieren.

Achtung: Ein einmal hochgeladener Schlüssel (mitsamt E-Mailadresse) kann nicht mehr auf einfache Art gelöscht werden. Ihre E-Mailadresse ist hiermit für alle öffentlich sichtbar.

Eine Alternative wäre es zum Beispiel, dass Sie Ihren öffentlichen Schlüssel z.B. auf Ihrer Homepage bekannt geben.